



User Personal Profile Management Plan

Product context

Orviohub has one central user account shared across all applications:

```
accounts.orviohub.com
```

A user can:

- Own a workspace.
- Manage a workspace as an administrator.
- Work inside another person's workspace.
- Belong to multiple workspaces.
- Have different roles in different workspaces.
- Use multiple Orviohub applications.

Personal profile management must remain separate from workspace management.

Example:

```
User: Code X  
Owns: Code X Stores  
Role in Code X Stores: Owner
```

```
User: Mary  
Owns: No workspace  
Member of: Code X Stores  
Role: Sales Attendant
```

Mary still needs complete personal-profile management even though she does not own a workspace.

Main principle

A user's personal account belongs to the user. Workspace settings belong to the workspace owner or authorized workspace administrators.

A workspace owner should not be able to:

- Change a worker's personal name.

- Change a worker's personal email.
- Change a worker's password.
- View a worker's private security activity.
- Delete a worker's personal account.
- Control the worker's other workspace memberships.

A workspace administrator may manage only the worker's access to that particular workspace.

1. Profile areas

The profile system should contain:

1. Personal information.
2. Contact information.
3. Profile photo.
4. Login methods.
5. Password.
6. Active sessions.
7. Security activity.
8. Notification preferences.
9. Language and regional preferences.
10. Privacy and data.
11. Connected applications.
12. Account deletion.
13. Workspace memberships.
14. Product preferences.

Recommended routes

```
accounts.orviohub.com/profile
accounts.orviohub.com/profile/personal
accounts.orviohub.com/profile/contact
accounts.orviohub.com/profile/security
accounts.orviohub.com/profile/sessions
accounts.orviohub.com/profile/activity
accounts.orviohub.com/profile/notifications
accounts.orviohub.com/profile/preferences
accounts.orviohub.com/profile/privacy
accounts.orviohub.com/profile/workspaces
accounts.orviohub.com/profile/delete
```

Workspace access should be managed separately:

```
app.orviohub.com/workspaces  
inventory.orviohub.com/settings/members
```

2. Personal information

Screen

```
accounts.orviohub.com/profile/personal
```

Fields

Required

- First name.
- Last name.

Optional

- Display name.
- Profile photo.
- Preferred name.
- Job title.
- Department.
- Bio.

The job title and department may be useful inside workspace products but should not be confused with workspace roles.

Example:

```
Personal job title: Store Assistant  
Workspace role: Sales Attendant
```

User stories

View personal information

As a user, I want to view my personal profile so that I know what information Orviohub stores about me.

Update name

As a user, I want to update my name so that my identity appears correctly in receipts, team lists, notifications, and reports.

Add display name

As a user, I want to set a display name so that colleagues can identify me easily.

Add job title

As a user, I want to add my job title so that team members understand my professional function.

Upload profile photo

As a user, I want to upload a profile photo so that other workspace members can recognize me.

Remove profile photo

As a user, I want to remove my profile photo so that I can control how my account appears.

Acceptance criteria

- User can edit permitted personal fields.
- Changes are validated.
- User sees unsaved-change warning.
- Successful updates show confirmation.
- Update creates audit event.
- Other workspaces reflect the new global name where appropriate.
- Workspace role is not changed when job title changes.
- Existing transaction history remains intact.

3. Contact information

Fields

- Primary email.
- Additional email, future.
- Phone number.
- Country.
- State.

- City.
- Time zone.

Email requirements

- Primary email must be unique.
- Email must be normalized.
- New email must be verified.
- Existing email remains active until new one is verified.
- Security notification is sent after change.
- Active sessions may be revoked after a high-risk email change.

Phone requirements

- Phone number is optional initially.
- Normalize to international format.
- Send OTP before marking verified.
- Phone can be used for account recovery in a future release.
- Do not expose a user's phone to every workspace member by default.

User stories

Update email

As a user, I want to change my email so that I can keep my account connected to an address I actively use.

Verify email

As a user, I want to verify my email so that my account and recovery options are secure.

Add phone number

As a user, I want to add my phone number so that Orviohub can use it for recovery, notifications, or future OTP login.

Change phone number

As a user, I want to update my phone number when it changes.

Manage visibility

As a user, I want to control whether my phone number is visible to workspace members.

Acceptance criteria

- Email changes require re-authentication.
- New email receives verification link.
- Old email receives change notification.
- Phone changes require verification.
- Unverified contact information is visibly marked.
- Workspace admins cannot alter personal contact data.
- Contact changes create audit records.

4. Profile photo management

Requirements

- Upload image.
- Crop image.
- Preview image.
- Replace image.
- Remove image.
- Validate file size.
- Validate MIME type.
- Compress image.
- Store in protected object storage.
- Generate thumbnail.
- Prevent executable uploads.

User stories

As a user, I want to upload a profile picture so that teams can identify me visually.

As a user, I want to remove my picture so that I can return to a default avatar.

Acceptance criteria

- Only the user can change their global profile image.
- Image is displayed across authorized workspace contexts.
- Deleted image is removed or made inaccessible according to retention policy.
- Image URL does not expose private storage credentials.

5. Login methods

Screen

```
accounts.orviohub.com/profile/security/connected-accounts
```

Supported methods

- Email/password.
- Google.
- Facebook.
- Future phone OTP.
- Future Apple.
- Future Microsoft.
- Future passkeys.

User stories

View login methods

As a user, I want to see which login methods are connected to my account so that I understand how I can sign in.

Connect Google

As a user, I want to connect Google so that I can sign in quickly.

Connect Facebook

As a user, I want to connect Facebook so that I have another way to sign in.

Disconnect provider

As a user, I want to disconnect a provider so that I can remove access I no longer use.

Prevent account logout

As a user, I should not be allowed to remove my only remaining login method.

Acceptance criteria

- User must re-authenticate before linking or unlinking a provider.
- Provider identity is verified server-side.
- Provider subject is stored as the stable identity key.
- Account linking does not create duplicates.
- User cannot remove the only usable login method.
- Linking and unlinking create notifications and audit events.
- Provider tokens and secrets are not exposed to the frontend.

6. Password management

Screen

```
accounts.orviohub.com/profile/security/password
```

Requirements

- Change password.
- Validate current password.
- Validate new password.
- Confirm new password.
- Show password strength.
- Revoke other sessions after change.
- Send security notification.
- Rate-limit attempts.

User stories

As a user, I want to change my password so that I can protect my account.

As a user, I want to reset my password if I forget it.

As a user, I want other sessions to be logged out after a password change so that an old device cannot remain connected.

Acceptance criteria

- Current password is required.
- New password cannot match the old password.
- Password is hashed securely.
- Existing sessions are revoked according to security policy.
- Password is never logged.
- User receives a security notification.
- Failed attempts are rate-limited.

7. Active sessions

Screen

```
accounts.orviohub.com/profile/security/sessions
```

Session information

Show:

- Device name.
- Browser.
- Operating system.
- Approximate location.
- IP address partially masked.
- Last active time.
- Login method.
- Current-session label.
- Session status.

Actions

- Sign out one session.
- Sign out all other sessions.
- Sign out all sessions.
- Report suspicious session.

User stories

As a user, I want to see where my account is signed in so that I can detect suspicious access.

As a user, I want to sign out a lost device so that the account remains secure.

As a user, I want to sign out of all other sessions after using a shared computer.

Acceptance criteria

- User can revoke another session.
- Revoked session stops working.
- Current session is clearly identified.
- Session information is not exposed to workspace administrators.
- Session revocation creates an audit event.
- Suspicious-session action provides support or security guidance.

OWASP recommends secure session lifecycle management, secure cookie handling, session expiration, and session invalidation. ^[1] ^[2]

8. Security activity

Screen

```
accounts.orviohub.com/profile/security/activity
```

Events shown

- Successful login.
- Failed login.
- Password changed.
- Email changed.
- Phone changed.
- Provider linked.
- Provider unlinked.
- Session revoked.
- Account recovery.
- Workspace joined.
- Workspace left.

User stories

As a user, I want to review security activity so that I can detect unauthorized account actions.

As a user, I want to report an unfamiliar login so that I can secure my account.

Acceptance criteria

- Events are shown newest first.
- Sensitive details are masked.
- User can filter by date and event type.
- User can mark an event as suspicious.
- Audit records cannot be edited by the user.
- Security notifications link to the relevant activity.

9. Notification preferences

Screen

```
accounts.orviohub.com/profile/notifications
```

Notification categories

Security

Cannot be fully disabled:

- New login.
- New device.
- Password change.
- Email change.
- Provider linking.
- Session revocation.
- Account deletion request.

Workspace

- Invitation received.
- Member changes.
- Role changes.
- Workspace updates.

Product

- Inventory low stock.
- Inventory sync issue.
- Task assignment.
- Booking reminder.

Billing

For billing owner or authorized billing manager:

- Payment successful.
- Payment failed.
- Trial ending.
- Plan changed.
- Subscription cancelled.

Marketing

Optional:

- Product announcements.
- Promotions.
- Educational material.
- Surveys.

User stories

As a user, I want to choose which non-critical notifications I receive so that Orviohub does not become noisy.

As a worker, I want to receive task or inventory notifications relevant to my assigned work.

As a user, I should always receive important security notifications.

Acceptance criteria

- Security notifications remain enabled.
- User can select email or in-app where supported.
- Product preferences can be configured per application.
- Workspace administrators cannot change personal marketing preferences.
- Notification preferences apply across all products unless overridden at the product level.

10. Regional and display preferences

Fields

- Time zone.
- Country.
- Language.
- Date format.
- Number format.
- Currency display preference.
- First day of week.
- Theme.
- Compact or comfortable layout.

User stories

As a user, I want to set my time zone so that notifications and activity timestamps are accurate.

As a user, I want to select a preferred language so that the interface is easier to understand.

As a user, I want to choose light or dark mode so that I can use the application comfortably.

Important distinction

User currency preference is for display.

Workspace currency controls business transactions.

Example:

```
User display preference: USD
Workspace accounting currency: NGN
```

The user's display preference must not change the Inventory workspace's transaction currency.

11. Workspace memberships from personal profile

Screen

```
accounts.orviohub.com/profile/workspaces
```

What the user sees

For each workspace:

- Workspace name.
- Workspace logo.
- Workspace type.
- Role.
- Products accessed.
- Membership status.
- Joined date.
- Owner or administrator name.
- Leave workspace action.

User stories

View memberships

As a user, I want to see all workspaces I belong to so that I understand where I have access.

Leave workspace

As a worker, I want to leave a workspace when I no longer work with that organization.

View roles

As a user, I want to see my role in each workspace and product.

Switch workspace

As a user, I want to open another workspace without signing in again.

Leave-workspace rules

A worker can leave a workspace if:

- They are not the only owner.
- No ownership transfer is pending.
- No special policy prevents leaving.

If the user is the only owner:

- Show Transfer ownership.
- Do not allow direct leaving.
- Explain the reason.

Important distinction

Leaving a workspace does not delete the user's Orviahub account.

It only removes membership from that workspace.

12. Privacy and personal data management

The Nigeria Data Protection Commission identifies rights including being informed, access, rectification, objection, restriction, portability, and erasure. ^[3]

Screen

```
accounts.orviahub.com/profile/privacy
```

Functions

- View privacy notice.
- View stored personal data.
- Download personal data.
- Correct inaccurate information.
- Manage consent.
- Withdraw marketing consent.
- Request deletion.
- View connected services.
- View data-retention information.

User stories

As a user, I want to know what personal data Orviahub stores about me.

As a user, I want to download my personal account data.

As a user, I want to correct inaccurate personal information.

As a user, I want to withdraw marketing consent.

As a user, I want to request account deletion.

Account export

The export may include:

- Personal profile.
- Authentication identities, without secrets.
- Workspace memberships.
- Notification preferences.
- Security activity summary.
- Consents.
- Audit events associated with the user.
- Product records the user is entitled to access.

Do not include:

- Other users' private data.
- Passwords.
- Raw session tokens.
- Provider secrets.
- Data the user is not authorized to access.

Account deletion

Before deletion:

- Re-authenticate user.
- Explain consequences.
- Display workspaces owned.
- Require ownership transfer or workspace closure.
- Display products affected.
- Require explicit confirmation.
- Apply cooling-off period if selected.
- Send confirmation notification.

For workers:

- Remove personal account access after confirmation.
- Preserve business records where necessary.
- Anonymize historical “created by” references if required by policy.
- Do not delete the employer’s inventory or task records automatically.

13. Ownership differences

User who owns a workspace

The user can manage:

- Personal profile.
- Login methods.
- Personal security.
- Own workspace settings.
- Workspace members.
- Workspace roles.
- Product access.
- Billing, if billing owner.
- Workspace data export.
- Workspace archive or deletion.

The user cannot use workspace ownership to manage another member's private account.

User who does not own a workspace

The user can manage:

- Personal profile.
- Login methods.
- Personal security.
- Notification preferences.
- Personal workspace list.
- Their own product preferences.
- Leaving a workspace where permitted.
- Personal data export.
- Personal account deletion.

The user cannot manage:

- Workspace name.
- Workspace billing.
- Other members.
- Workspace roles.
- Workspace deletion.
- Workspace-wide product access.

Worker role management

A worker's workspace administrator can:

- Change workspace role.
- Change product role.
- Change branch assignment.
- Suspend workspace access.
- Remove workspace membership.

The administrator cannot:

- Change the worker's personal email.
- Change the worker's password.
- Delete the worker's Orvionhub account.
- Access private security sessions.
- Change the worker's other workspaces.

14. Shared profile and product behavior

The global profile should be shared across products:

```
accounts.orvionhub.com/profile
```

But each product can store product-specific preferences.

Global profile data

- Name.
- Profile image.
- Email.
- Phone.
- Time zone.
- Language.
- Security.
- Notifications.

Inventory-specific preferences

- Preferred branch.
- Receipt-printing preference.
- POS layout.

- Default payment method.
- Product-list density.
- Scanner preference.

Task Management-specific preferences

- Default project view.
- Task reminder settings.
- Calendar preference.
- Notification frequency.

Do not place Inventory settings in the global profile.

15. REST API plan

Personal profile routes

```
GET    /v1/users/me
PATCH /v1/users/me
POST   /v1/users/me/avatar
DELETE /v1/users/me/avatar
PATCH /v1/users/me/contact
POST   /v1/users/me/email/change
POST   /v1/users/me/email/verify
POST   /v1/users/me/phone/verify
```

Security routes

```
POST   /v1/users/me/password/change
GET     /v1/users/me/sessions
DELETE  /v1/users/me/sessions/:sessionId
POST    /v1/users/me/sessions/revoke-all
GET     /v1/users/me/security-activity
GET     /v1/users/me/identities
POST    /v1/users/me/identities/:provider/link
DELETE  /v1/users/me/identities/:provider
```

Preference routes

```
GET     /v1/users/me/preferences
PATCH  /v1/users/me/preferences
GET     /v1/users/me/notifications/preferences
PATCH  /v1/users/me/notifications/preferences
```

Privacy routes

```
GET    /v1/users/me/data-summary
POST   /v1/users/me/data-export
GET    /v1/users/me/data-export/:exportId
POST   /v1/users/me/deletion-request
POST   /v1/users/me/deletion-request/cancel
```

Membership routes

```
GET    /v1/users/me/workspaces
POST   /v1/users/me/workspaces/:workspaceId/leave
GET    /v1/users/me/workspaces/:workspaceId/access
```

16. Convex schema plan

users

```
_id
email
emailNormalized
emailVerifiedAt
firstName
lastName
displayName
avatarUrl
phone
phoneVerifiedAt
country
state
city
timezone
language
dateFormat
numberFormat
theme
status
createdAt
updatedAt
lastLoginAt
```

authIdentities

```
_id
userId
provider
providerSubject
providerEmail
providerEmailVerified
```

```
createdAt  
lastUsedAt  
linkedAt  
metadata
```

userPreferences

```
_id  
userId  
theme  
language  
timezone  
dateFormat  
numberFormat  
marketingEmailEnabled  
productEmailEnabled  
securityEmailEnabled  
updatedAt
```

userSessions

```
_id  
userId  
sessionHash  
deviceId  
deviceName  
browser  
operatingSystem  
ipAddress  
approximateLocation  
authenticationMethod  
createdAt  
lastActiveAt  
expiresAt  
revokedAt
```

userConsents

```
_id  
userId  
consentType  
version  
granted  
grantedAt  
withdrawnAt  
source
```

accountDeletionRequests

```
_id  
userId  
status  
reason  
requestedAt  
scheduledDeletionAt  
cancelledAt  
completedAt
```

dataExportRequests

```
_id  
userId  
status  
requestedAt  
completedAt  
expiresAt  
storageReference
```

userAuditLogs

```
_id  
userId  
eventType  
targetType  
targetId  
severity  
metadata  
requestId  
ipAddress  
userAgent  
createdAt
```

Indexes

```
users.by_email  
authIdentities.by_user  
authIdentities.by_provider_subject  
userSessions.by_user  
userSessions.by_user_active  
userConsents.by_user  
userAuditLogs.by_user  
userAuditLogs.by_user_created  
dataExportRequests.by_user  
accountDeletionRequests.by_user
```

Use Convex indexes for user and session lookups rather than broad scans. Convex documentation recommends indexes for efficient queries and schema validation for consistent data types. ^[4] ^[5]

17. Fastify module structure

```
src/modules/profile/  
├─ profile.routes.ts  
├─ profile.controller.ts  
├─ profile.service.ts  
├─ profile.repository.ts  
├─ profile.schemas.ts  
├─ profile.permissions.ts  
├─ profile.mapper.ts  
└─ profile.events.ts  
  
src/modules/security/  
├─ security.routes.ts  
├─ security.service.ts  
├─ session.service.ts  
├─ identity.service.ts  
└─ security.events.ts  
  
src/modules/privacy/  
├─ privacy.routes.ts  
├─ privacy.service.ts  
├─ export.service.ts  
└─ deletion.service.ts  
  
src/modules/preferences/  
├─ preference.routes.ts  
├─ preference.service.ts  
└─ notification-preference.service.ts
```

Request flow

```
Authenticate user  
  ↓  
Load user from session  
  ↓  
Validate request  
  ↓  
Require recent authentication for sensitive action  
  ↓  
Update user profile  
  ↓  
Write audit event  
  ↓  
Send security notification if necessary  
  ↓  
Return sanitized response
```

18. Sensitive-action re-authentication

Require re-authentication for:

- Email change.
- Password change.
- Phone change.
- Provider linking.
- Provider unlinking.
- Account deletion.
- Workspace ownership transfer.
- Billing changes.
- Export of sensitive data.
- Changing recovery methods.
- Disabling future MFA.

Re-authentication may be:

- Current password.
- OAuth reauthentication.
- Verified OTP.
- Recent session with sufficient authentication strength.

19. Implementation phases

Phase 1: Profile foundation

- User profile model.
- Profile screen.
- Name editing.
- Profile photo.
- Country and time zone.
- Shared profile API.
- Audit events.

Phase 2: Contact management

- Email change.
- Email verification.
- Phone number.
- Phone verification.
- Contact notifications.

Phase 3: Security

- Password change.
- Connected accounts.
- Google linking.
- Facebook linking.
- Active sessions.
- Logout-all.
- Security activity.

Phase 4: Preferences

- Notification settings.
- Language.
- Time zone.
- Theme.
- Date and number format.
- Product preferences.

Phase 5: Workspace memberships

- View workspaces.
- View roles.
- Leave workspace.
- Workspace access summary.
- Owner-specific restrictions.

Phase 6: Privacy

- Data summary.
- Data export.
- Consent management.
- Deletion request.

- Account recovery and support workflows.

Phase 7: Hardening

- Authorization testing.
- Privacy review.
- Tenant isolation.
- Session security.
- Rate limiting.
- File-upload security.
- Audit-log validation.
- Backup and recovery.

20. Acceptance criteria

Personal profile

- User can view their profile.
- User can edit name.
- User can edit optional profile details.
- User can upload and remove profile photo.
- Updates appear across authorized products.
- Profile changes do not change workspace roles.

Contact information

- User can change email securely.
- New email must be verified.
- User can add and verify phone.
- Contact-change notifications are sent.
- Workspace owners cannot edit workers' personal contact data.

Security

- User can change password.
- User can view active sessions.
- User can revoke a session.
- User can log out all sessions.
- User can view security activity.
- Provider linking requires re-authentication.

- User cannot remove the only login method.

Preferences

- User can control non-critical notifications.
- Security notifications remain enabled.
- User can set time zone.
- User can set language and display preferences.
- Product-specific preferences remain product-specific.

Workspace membership

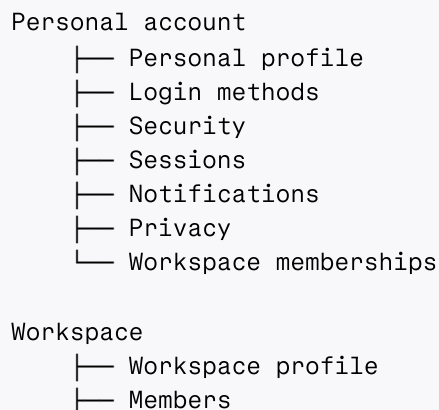
- User can see every workspace they belong to.
- User can see their role and product access.
- Worker can leave a workspace when allowed.
- Worker leaving does not delete their Orvionhub account.
- Workspace owner cannot be removed without ownership transfer.
- Workspace admins cannot access personal security settings.

Privacy

- User can request personal-data export.
- User can correct personal data.
- User can withdraw marketing consent.
- User can request account deletion.
- Deleting a worker account does not automatically delete workspace business records.
- Sensitive personal data is not exposed to other members.

Final recommended model

Use this separation:



- └─ Roles
- └─ Product access
- └─ Branches
- └─ Billing
- └─ Business data

For a workspace owner:

- Can manage:
- Their personal profile
 - Their workspace
 - Workspace members
 - Roles
 - Product access
 - Billing, if authorized

For a worker:

- Can manage:
- Their personal profile
 - Their login methods
 - Their security
 - Their notifications
 - Their own workspace memberships

The worker's membership gives them access to a workspace, but it does not transfer ownership of their personal Orvionhub account to that workspace.



1. https://cheatsheetseries.owasp.org/cheatsheets/Authentication_Cheat_Sheet.html
2. https://cheatsheetseries.owasp.org/cheatsheets/Session_Management_Cheat_Sheet.html
3. <https://ndpc.gov.ng/>
4. <https://docs.convex.dev/database/reading-data/indexes/>
5. <https://docs.convex.dev/database/schemas>
6. <https://a.storyblok.com/f/302089/x/ac8dcf7542/overview-of-the-new-nigerian-data-protection-act-ndpa-2023.pdf>
7. https://cert.gov.ng/ngcert/resources/Nigeria_Data_Protection_Act_2023.pdf
8. <https://docs.convex.dev/database/reading-data/indexes/indexes-and-query-perf>
9. <https://cheatsheetseries.owasp.org/IndexASVS.html>
10. <https://docs.convex.dev/database/reading-data/>
11. https://opencre.org/node/standard/OWASP_Cheat_Sheets/section/Session_Management_Cheat_Sheet
12. <https://deepwiki.com/OWASP/CheatSheetSeries/3-authentication-and-session-management>
13. https://assets.kpmg.com/content/dam/kpmg/ng/pdf/nigeria-data-protection-act2023_kpmg-review.pdf
14. <https://business.cch.com/CybersecurityPrivacy/NigerianGAID.pdf>

15. [https://isc.ng/publications/August-2023-Newsletter-Data-protection-regime-in-Nigeria-key-provisions-of-the-Nigeria-D
ata-Protection-Act-2023.pdf](https://isc.ng/publications/August-2023-Newsletter-Data-protection-regime-in-Nigeria-key-provisions-of-the-Nigeria-D
ata-Protection-Act-2023.pdf)
16. https://www.gelias.com/images/Newsletter/The_Nigerian_Data_Protection_Act_2023_-_A_Review.pdf